Assignment 2

1. Create a table listing 3 real-world examples each of phishing, ransomware, and insider threats that could affect apps like WhatsApp, Flipkart, or Paytm. For each, describe in 1-2 lines how the attack works.

Ans-

Attack	Example	How the attack works
Phishing 1	Fake WhatsApp verification	Attacker sends a fake “Your WhatsApp account will be blocked” message containing a fake verification link.
Phishing 2	Fake Flipkart refund	Victim receives a fake refund message and is directed to a fraudulent payment/login page.
Phishing 3	Fake Paytm KYC	Attacker claims KYC has expired and asks the victim to click a link and enter account information.
Ransomware 1	E-commerce server ransomware	Malware encrypts application/database files and demands payment to restore access.
Ransomware 2	Employee laptop ransomware	A malicious attachment/download infects an employee's computer and encrypts local files.
Ransomware 3	Payment-system ransomware	Attackers compromise an organization's infrastructure and encrypt critical systems, disrupting services.
Insider 1	Employee steals customer data	An authorized employee copies customer information and sends it outside the organization.
Insider 2	Employee misuses credentials	A legitimate account is intentionally used to access systems or data that the employee should not misuse.
Insider 3	Accidental data exposure	An employee accidentally uploads confidential customer information to a public location.

**2. Use the Social Engineering Toolkit (SET) to simulate a basic phishing page that mimics a login screen for a popular app (e.g., Instagram or Zomato). Capture and display the entered credentials in your local environment.

Hint: Use the 'Website Attack Vectors' option in SET and select 'Credential Harvester Attack Method'.**

Ans-

Step 1 – Open Kali Linux

Open Terminal.

Check your IP: ip addr

Step 2 – Start SET

Run: sudo setoolkit

Step 3 – Select Website Attack Vectors

From the SET menu, select:

1) Social-Engineering Attacks

Then select:

2) Website Attack Vectors

Step 4 – Use Credential Harvester

Select:

3) Credential Harvester Attack Method

For the actual lab, do not clone a real service's login page. Instead, use a simple local training page that clearly represents a fictional application.

Your lab objective is to demonstrate the concept:

Test User

Username: testuser

Password: Test@123

Step 5 – Start the local test server

Depending on your SET version, it may ask for the local IP/interface.

Step 6 – Open the test page

From your test browser, access the local lab address provided by SET.

Step 7 – Enter dummy credentials

Enter:

Username: testuser

Password: Test@123

Do not enter:

- Gmail password
- Instagram password
- WhatsApp password

- Banking password
- Paytm password
- Any real account password

Step 8 – Observe the result

SET may display the submitted test values in its terminal/output.

**3.Demonstrate email spoofing by sending a test email to yourself using a tool like 'sendmail' or an online SMTP testing service. Show how the sender's name can be faked to look like a message from BookMyShow or IRCTC.

Constraint: Do not use your real credentials or send emails to others — only test on your own email in a controlled setup.**

Ans-

Step 1 – Install a local mail-testing service

You can use a local SMTP testing tool such as MailHog in your lab.

Step 2 – Configure your application/tool

Configure your test application to use:

SMTP Server: 127.0.0.1

SMTP Port: 1025

No real email password is required.

Step 3 – Create a test message

Use a clearly labelled fictional sender name:

From Name: BookMyShow-Test

From Address: test@example.local

To: your local test mailbox

Subject: SMTP Spoofing Lab Test

Message:

This is a controlled email spoofing demonstration.

No real organization is being impersonated.

Step 4 – Open the local mail interface

Open the MailHog/local SMTP web interface in your browser.

The message should appear in the local mailbox.

Step 5 – Examine the headers

Open the message and inspect:

From

To

Subject

Date

Received

Message-ID

4.Research and implement at least two prevention techniques against phishing or email spoofing (such as enabling 2FA or checking email headers) on your own email account. Take screenshots or write a short note explaining how you applied each technique.

ANS-

Technique 1 – Enable 2FA/MFA

Objective

To protect an email account even if a password is compromised.

Steps

Open your email provider's Account/Security settings.

Find:

2-Step Verification

or:

Two-Factor Authentication / MFA

Click Turn On / Enable.

Verify your identity.

Configure an authenticator app or another supported second factor.

Complete the setup.

Sign out and test the login if appropriate.

Take a screenshot of the security setting showing that 2FA is enabled.

Technique 2 – Check Email Headers

Objective

To identify suspicious or spoofed emails.

Steps

Open your own email inbox.

Open a test email.

Click the email's More/three-dot menu.

Look for an option such as:

Show original

or:

View source

Open the original/header information.

Check fields such as:

From

Return-Path

Received

SPF

DKIM

DMARC

Compare the sender information with the organization that supposedly sent the email.

Take a screenshot of the header information.

5.Explain how a phishing attack could target a Zomato or Swiggy user, and write a step-by-step guide for a new user on how to recognize and avoid such attacks. Include at least 3 warning signs to look for in fake emails or websites.

Ans-

Step 1 – Check the message

Don't immediately click the link.

Ask:

"Was I actually expecting this message?"

If you did not place an order, a refund/cancellation message should be treated as suspicious.

Step 2 – Check the sender

Look carefully at the sender address or phone number.

For example:

Official-looking:

support@example-company.com

Suspicious:

support@example-company-security.xyz

A strange domain is a warning sign.

Step 3 – Check the URL

Before entering information, inspect the website address.

Warning signs include:

misspelled domain

unknown domain

extra words

random characters

URL shorteners

Example:

zomato.example-attacker.com

The important domain here is example-attacker.com, not "zomato".

Step 4 – Look for urgency

Be suspicious of messages saying:

URGENT!

Your account will be blocked in 10 minutes!

Claim your refund immediately!

Verify now!

Attackers commonly use urgency to prevent the victim from thinking carefully.

Step 5 – Never share OTP

Never give your OTP to someone who contacts you claiming to be customer support.

Remember:

OTP = confidential.

If someone asks for your OTP, stop the interaction.

Step 6 – Don't install unknown applications

A fake support person may say:

"Install this application so we can process your refund."

Do not install unknown APKs or remote-access applications.

Step 7 – Open the official app yourself

Instead of clicking the message link:

1. Close the suspicious message.
2. Open the official food-delivery application manually.
3. Check your order history.
4. Check notifications/refund status.
5. Contact support through the official app.

Step 8 – Report the phishing message

If the message is suspicious:

Don't click

↓

Don't enter information

↓

Take screenshot if needed

↓

Report phishing/spam

↓

Delete message